

Chapter 3: Security Applications & Devices

CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

Learning Objectives

- Explain the purpose of common security applications and devices
- Understand endpoint, network, and data protection tools
- Differentiate between IDS, IPS, and firewalls
- Discuss DLP, encryption, and BIOS security controls
- Evaluate strategies for securing storage and removable media

Overview

Security applications and devices form the **defense-in-depth layers** of an organization's infrastructure.

They operate at different levels:

- **Host level:** antivirus, personal firewall, endpoint protection
- **Network level:** IDS/IPS, firewalls, content filters
- **Data level:** encryption, DLP, access control

Removable Media Controls

Risks: malware infection, data exfiltration, insider threats

Controls:

- Disable or restrict USB ports
- Encrypt all files stored on removable drives
- Implement **Removable Media Policies** and logging
- Use **Data Loss Prevention (DLP)** to monitor transfers

 *Never trust unverified removable devices.*

Network Attached Storage (NAS) & Storage Area Network (SAN)

Storage Type	Description	Key Security Practices
NAS	Connects directly to the LAN, file-level access	Encrypt data, enable RAID, authenticate users
SAN	Dedicated high-speed block storage network	Use encryption, isolate SAN from user LAN, log access

Software Firewalls

A **software firewall** protects a single host by filtering inbound/outbound traffic.

Examples:

- Windows Firewall
- macOS PF / IPFW
- Linux `iptables` / `firewalld`

Features:

- Port and protocol filtering
- Application rules
- Logging and alerting



Many endpoint protection suites now integrate firewall functions.

Intrusion Detection Systems (IDS)

Definition: Monitors and analyzes network or system activity to detect suspicious or malicious behavior.

Type	Description
HIDS (Host-based IDS)	Installed on individual systems; analyzes log files and system events
NIDS (Network-based IDS)	Monitors network traffic at strategic points; uses packet capture

Detection Methods:

- Signature-based
- Policy-based
- Anomaly-based (statistical baseline comparison)

Intrusion Prevention Systems (IPS)

Definition: Extends IDS by actively blocking or mitigating detected threats in real time.

- Works **in-line** with traffic flow
- Can drop packets, reset connections, or quarantine hosts
- Useful against brute-force, exploit, and DoS patterns

IDS vs. IPS:

Feature	IDS	IPS
Action	Alert only	Alert + Block
Placement	Out-of-band	In-line
Primary Use	Detection	Prevention

IDS/IPS Alert Types

Alert Type	Description
True Positive	Malicious activity correctly identified
False Positive	Legitimate activity misidentified as malicious
True Negative	Normal activity correctly ignored
False Negative	Malicious activity undetected

Goal: minimize false positives while maintaining detection accuracy.

Pop-up Blockers & Content Filters

- **Pop-up blockers:** prevent intrusive JavaScript pop-ups and drive-by malware downloads
- **Content filters:** restrict access to malicious or inappropriate web content
 - Filter by keyword, URL, MIME type, or file signature
 - Applied at browser, proxy, or firewall level

 *Keep browsers and extensions patched to prevent exploit kits.*

Data Loss Prevention (DLP)

Definition: Technology designed to detect and prevent unauthorized data disclosure.

Forms of DLP:

- **Endpoint DLP:** monitors file operations (copy, print, upload)
- **Network DLP:** monitors data in transit
- **Storage DLP:** scans data at rest
- **Cloud DLP:** monitors SaaS and cloud repositories

 DLP enforces compliance with data protection laws (GDPR, HIPAA, PDPA).

Securing the BIOS/UEFI

Basic Input/Output System (BIOS) and **Unified Extensible Firmware Interface (UEFI)** control system startup.

Security Steps:

1. Update (flash) BIOS/UEFI to latest version
2. Set a **firmware password**
3. Configure **boot order** (disable boot from USB/CD)
4. Disable unused ports/devices
5. Enable **Secure Boot** to validate signed OS loaders

 *Firmware security prevents pre-boot rootkits.*

Securing Storage Devices

Goals: protect confidentiality and integrity of stored data.

Best Practices:

- Encrypt sensitive data
- Limit access using authentication and ACLs
- Audit and log access events
- Destroy retired storage securely (degaussing or shredding)

Disk Encryption

Purpose: Convert readable data into ciphertext to prevent unauthorized access.

Types:

- **Full Disk Encryption (FDE):** encrypts entire drive (e.g., BitLocker, FileVault)
- **Self-Encrypting Drives (SED):** hardware-based FDE with onboard crypto module
- **File/Folder Encryption:** user-level encryption (EFS, GPG)

Hardware Support:

- **TPM (Trusted Platform Module):** stores encryption keys securely
- **HSM (Hardware Security Module):** manages cryptographic operations centrally

Encryption Key Concepts

- **AES (Advanced Encryption Standard):** symmetric encryption (128/192/256-bit)
- **RSA / ECC:** asymmetric cryptography used for key exchange and digital signatures
- **Key Management:** generate, rotate, and securely store keys; revoke when compromised

 *Encryption adds security but can affect performance.*

Integration of Security Controls

Security applications should be layered and coordinated:

- Endpoint protection (AV + firewall)
- Network security (IDS/IPS, DLP, content filter)
- Data encryption and key management
- Centralized logging (SIEM)

Goal: unified visibility and correlation across layers.

Example Architecture

Defense-in-Depth Stack: